KỊCH BẢN THUYẾT TRÌNH & HƯỚNG DẪN DEMO THỰC CHIẾN TOÀN DIỆN

Hệ thống Quản lý Đào tạo EduFlaw — BTL Cơ sở An toàn thông tin (PTIT Hà Nội)

Nhóm 7 — Khóa D24
GVHD: **ThS. Đỗ Xuân Chợ**
Chuẩn đánh giá: **OWASP Top 10:2025**

1. PHÂN BỔ THỜI GIAN 15 PHÚT BẢO VỆ ĐỒ ÁN TRƯỚC HỘI ĐỒNG

Phân đoạn	Trọng tâm nội dung	Công cụ / Thao tác	Mục tiêu thuyết phục Thầy cô
MÀN 1 (3 phút)	Slide Kiến trúc & Mô hình đe dọa	Slide Canva / PPTX	Tổng quan EduFlaw; 4 trọng tâm OWASP 2025: A01 (IDOR), A03 (Supply Chain), A07 (Auth), A10 (Fail-Closed).
MÀN 2 (4 phút)	**Demo Web thật & DevTools**	Nhấp đúp `1_CHAY_WEB_DEMO.bat`	**Minh chứng A01 & A03 trên Web thật** (Phân quyền 3 vai trò, thử IDOR trên URL, chặn SRI đỏ rực ở F12).
MÀN 3 (5 phút)	**Live Pentest Console**	Nhấp đúp `4_CHAY_KIEM_THU_PENTEST.bat`	**Tấn công tự động 7 kịch bản:** A01 (3 test), A03 (SRI live), A07 (Khóa 429), A10 (0 lỗi 5xx), Fuzzing 69 routes, CSDL.
MÀN 4 (3 phút)	Pháp chứng CSDL & Phản biện	Soi CSDL MySQL + Trả lời Q&A	Chứng minh CCCD mã hóa AES-256-GCM, Audit Trail sửa điểm và giải quyết thuyết phục 7 câu hỏi phản biện.

2. KỊCH BẢN BIỂU DIỄN MÀN 2: ỨNG DỤNG WEB THẬT & DEVTOOLS F12

💡 **Khởi động:** Nhấp đúp chuột vào `1_CHAY_WEB_DEMO.bat`. Web tự khởi động tại `http://127.0.0.1:5000/login` với các nút đăng nhập 1-click tiện lợi.

A01:2025 Biểu Diễn Chống IDOR & Phân Quyền 3 Vai Trò Trực Tiếp Trên Web

1. Bấm nút **"Sinh viên 1"** (tài khoản `b24dcat001`). Vào mục **Xem điểm học phần** (URL: `/student/grades`). Bảng điểm của Đặng Tuấn Bình hiện ra.
2. **Thao tác tấn công IDOR:** Trên URL trình duyệt, gõ thêm: `?student_id=2` rồi bấm Enter.
   Hiện tượng: Web tải lại nhưng **vẫn hiển thị đúng bảng điểm của Sinh viên 1**. Tham số client gửi lên bị vô hiệu hóa hoàn toàn.
3. **Thao tác tấn công leo thang dọc:** Gõ thẳng trên thanh URL: `http://127.0.0.1:5000/master` rồi bấm Enter.
   Hiện tượng: Trình duyệt **lập tức đá văng về `/student`**, sinh viên không xem được bảng quản trị.
4. **Thao tác can thiệp chéo giữa 2 GV:** Đăng xuất, bấm **"Giảng viên 2"** (gv.002, không dạy lớp 243198). Thử chỉnh sửa ô điểm của lớp gv.001 -> Web hiển thị cảnh báo đỏ cấm quyền: ⛔ `Bạn không có quyền chỉnh sửa điểm của lớp học phần này!` (HTTP 403).

> **LỜI THOẠI THUYẾT MINH TRƯỚC HỘI ĐỒNG:**
> *"Kính thưa Thầy, em xin chứng minh khả năng phòng thủ lỗ hổng Phân quyền A01 ngay trên web thật. Kẻ tấn công dùng tài khoản Sinh viên 1, cố tình sửa URL thành student_id=2 để soi trộm điểm của bạn khác. Như Thầy thấy, màn hình vẫn hiển thị nguyên vẹn điểm của Sinh viên 1. Lý do vì máy chủ EduFlaw tuyệt đối không tin tham số client mà neo chặt danh tính vào session đã ký số session['user_id']. Khi sinh viên cố tình gõ URL quản trị /master, hệ thống lập tức chặn đứng và chuyển hướng về trang sinh viên. Khi Giảng viên 2 cố sửa trộm điểm của lớp do Giảng viên 1 phụ trách, máy chủ từ chối với mã HTTP 403 Forbidden."*

A03:2025 Biểu Diễn Cơ Chế Chống Đầu Độc CDN Bằng W3C SRI Trong Chrome / Edge DevTools (F12)

1. Tại trang `http://127.0.0.1:5000/login`, bấm phím **F12** để mở Developer Tools.
2. Chọn tab **Elements**, chỉ vào dòng thẻ:
   `<script src="https://cdn.jsdelivr.net/...sweetalert2@11.10.5/..." integrity="sha256-+0Qf8IHM..." crossorigin="anonymous"></script>`
3. **Thao tác thực chiến "ăn điểm 10":** Nhấp đúp vào giá trị thuộc tính `integrity`, cố tình sửa ký tự cuối cùng thành chữ khác (ví dụ: đổi `I=` thành `X=`) rồi bấm Enter. Sau đó nhấn **Ctrl + F5** tải lại trang.
4. Chuyển ngay sang tab **Console** của DevTools.

> **LỜI THOẠI THUYẾT MINH TRƯỚC HỘI ĐỒNG:**
> *"Thưa Thầy, A03:2025 là hạng mục mới về Chuỗi cung ứng phần mềm. EduFlaw sử dụng thư viện SweetAlert2 từ CDN jsDelivr. Nhóm áp dụng chuẩn W3C Subresource Integrity (SRI) ghim mã băm SHA-256 và cờ crossorigin='anonymous'. Em vừa sửa thử 1 ký tự mã băm trong DevTools để giả lập kịch bản máy chủ CDN bị hacker chèn mã độc đánh cắp mật khẩu. Khi tải lại trang, Thầy thấy ngay trên tab Console xuất hiện dòng chữ đỏ rực: 'Failed to find a valid digest in the integrity attribute... The resource has been blocked'. Trình duyệt phát hiện mã băm không khớp và tiêu diệt file ngay tại cổng mạng, bảo vệ 100% tài khoản người dùng."*

3. KỊCH BẢN BIỂU DIỄN LIVE PENTEST CONSOLE (MÀN 3 — TRỌNG TÂM)

💡 **Khởi động:** Tại thư mục gốc, nhấp đúp `4_CHAY_KIEM_THU_PENTEST.bat`. Cửa sổ màu đen xuất hiện.

BÀI 1 Kiểm Thử Kiểm Soát Truy Cập & Chống IDOR (OWASP A01:2025)

Thao tác: Tại menu chính, bạn gõ số `1` rồi bấm **Enter**.

> **LỜI THOẠI THUYẾT MINH TRƯỚC HỘI ĐỒNG:**
> *"Em xin khởi chạy bài kiểm thử tự động A01. Công cụ thực hiện cùng lúc 3 kịch bản: Thứ nhất, gửi yêu cầu IDOR ngang với student_id=9999, máy chủ phớt lờ tham số và chỉ trả về dữ liệu của phiên đăng nhập trong 21ms. Thứ hai, dùng phiên sinh viên quét 5 endpoint quản trị /master và /admin, cả 5 đều bị chặn 100% với mã HTTP 302 chuyển hướng an toàn. Thứ ba, dùng tài khoản Giảng viên 2 gửi request ngầm sửa điểm lớp của Giảng viên 1, máy chủ lập tức từ chối với mã HTTP 403 Forbidden kèm thông báo cấm quyền."*

BẢN CHẤT KỸ THUẬT & KẾT QUẢ ĐO ĐẠC:

- **Kịch bản 1.1 (IDOR Ngang):** Hàm `view_grades()` trong `student.py` lấy `session['user_id']` trực tiếp từ cookie Flask được ký HMAC-SHA256, vô hiệu hóa hoàn toàn kỹ thuật thao túng URL Parameter.
- **Kịch bản 1.2 (Leo thang Dọc):** 5/5 route quản trị (`/master` , `/master/students` , `/master/grades` , `/admin` , `/admin/grades`) được bảo vệ bằng `@role_required` , trả về HTTP 302 điều hướng an toàn.
- **Kịch bản 1.3 (Can thiệp Chéo):** API `/admin/grades/api/auto-save` xác thực quyền sở hữu dòng điểm `WHERE lecturer_id == session['user_id']` , chặn đứng với HTTP 403 Forbidden.

BÀI 2 Rà Soát Chuỗi Cung Ứng & Kiểm Tra Toàn Vẹn SRI (OWASP A03:2025)

Thao tác: Bấm Enter quay lại menu, gõ số `2` rồi bấm **Enter**.

> **LỜI THOẠI THUYẾT MINH TRƯỚC HỘI ĐỒNG:**
> *"Tiếp theo là bài kiểm thử chuỗi cung ứng A03. Script tự động phân tích trang đăng nhập của EduFlaw, bốc tách thẻ script và tải file SweetAlert2 thực tế từ CDN jsDelivr về tính mã băm SHA-256 theo thời gian thực. Kết quả băm ra trùng khớp 100% với chuỗi sha256-+0Qf8IHM... đã ghim. Đồng thời kịch bản mô phỏng tiêm 1 byte mã độc vào file: mã băm lập tức bị lệch và kích hoạt chính sách chặn của W3C SRI. Cuối cùng, công cụ kiểm toán file requirements.txt xác nhận 10/10 gói thư viện Python đều được ghim cứng phiên bản tuyệt đối với toán tử ==."*

BẢN CHẤT KỸ THUẬT & KẾT QUẢ ĐO ĐẠC:

- **Kịch bản 2.1 (Kiểm toán SRI Live):** Tải file trực tiếp từ CDN, tính Base64 SHA-256 digest khớp chính xác 100% với giá trị ghim trong mã nguồn, chứng minh tính toàn vẹn của mã nhúng bên thứ ba.
- **Kịch bản 2.2 (PoC CDN Poisoning):** Tiêm đoạn mã độc giả định `navigator.sendBeacon(...)` làm thay đổi hash -> Trình duyệt từ chối thực thi với thông báo vi phạm SRI.
- **Kịch bản 2.3 (Dependency Pinning):** 10/10 thư viện trong `src/requirements.txt` ghim phiên bản cụ thể (Flask==3.1.3, PyMySQL==26.7.0...), loại bỏ nguy cơ Dependency Confusion và Typosquatting.

BÀI 3 **Kiểm Thử Chống Brute-Force & Khóa Tài Khoản (OWASP A07:2025)**

Thao tác: Bấm Enter quay lại menu, gõ số `3` rồi bấm **Enter**.

> **LỜI THOẠI THUYẾT MINH TRƯỚC HỘI ĐỒNG:**
> *"Ở bài 3 về Xác thực A07: Kẻ tấn công dội thử 7 mật khẩu sai liên tiếp vào tài khoản b24dcat001. Từ lần 1 đến 4, máy chủ trả về HTTP 200 báo sai mật khẩu. Đến lần thứ 5, hệ thống kích hoạt cơ chế khóa bảo vệ, trả về mã HTTP 429 Too Many Requests và khóa cứng IP cùng tài khoản trong 60 giây. Các lần 6 và 7 đều bị chặn ngay từ cổng vào chỉ trong 18ms."*

> **BẢN CHẤT KỸ THUẬT & KẾT QUẢ ĐO ĐẠC:**
> - **Cơ chế khóa kép (Dual-Scope Lockout):** Lưu vết cả `ip:127.0.0.1` và `user:b24dcat001@eduflaw.com` trong bảng `login_attempts`. Dù tin tặc đổi IP bằng VPN thì tài khoản sinh viên vẫn được bảo vệ.
> - **Phản hồi siêu tốc (18ms):** Từ chối request rác mà không tốn tài nguyên CPU xử lý hàm băm mật khẩu PBKDF2/Argon2.

BÀI 4 **Kiểm Thử Xử Lý Ngoại Lệ & Nguyên Tắc Fail-Closed (OWASP A10:2025)**

Thao tác: Bấm Enter quay lại menu, gõ số `4` rồi bấm **Enter**.

> **LỜI THOẠI THUYẾT MINH TRƯỚC HỘI ĐỒNG:**
> *"Tiếp theo là hạng mục mới A10: Xử lý ngoại lệ. Em gửi liên tục 23 payload dị dạng gồm SQLi, XSS, Path Traversal, Null Byte và chuỗi 10.000 ký tự vào API xác thực để ép máy chủ phát sinh lỗi. Kết quả đạt 0 lỗi 5xx trên toàn bộ 23 payload, độ trễ trung bình 20ms. Hệ thống bắt toàn bộ ngoại lệ theo nguyên tắc Fail-Closed: đóng cửa an toàn, không crash server và tuyệt đối không để lộ Stack Trace."*

BÀI 5 **Quét Toàn Diện Bề Mặt Tấn Công (Attack Surface Mapping — 69 Endpoint)**

Thao tác: Bấm Enter quay lại menu, gõ số `5` rồi bấm **Enter**.

> **LỜI THOẠI THUYẾT MINH TRƯỚC HỘI ĐỒNG:**
> *"Bài 5 thực hiện Fuzzing 69 đường dẫn để tự động vẽ bản đồ xác thực mà không cần đọc code trước: 23 route nghiệp vụ được bảo vệ bằng mã HTTP 302 chuyển hướng về /login; 40 endpoint rác hoặc file nhạy cảm như .env, .git, db.sql đều trả về 404 không tồn tại. Đồng thời công cụ chỉ ra chính xác đường dẫn debug /console của Werkzeug đang mở ở môi trường dev, chứng minh khả năng rà quét phát hiện điểm yếu của công cụ."*

BÀI 6 **Điều Tra Pháp Chứng CSDL & Bảo Vệ Dữ Liệu Lưu Trữ (Data-at-Rest)**

Thao tác: Bấm Enter quay lại menu, gõ số `6` rồi bấm **Enter**.

> **LỜI THOẠI THUYẾT MINH TRƯỚC HỘI ĐỒNG:**
> *"Em truy vấn trực tiếp vào CSDL MySQL: Thứ nhất, toàn bộ trường số CCCD của sinh viên đều hiển thị dưới dạng chuỗi mã hóa tiền tố enc:v1: bằng thuật toán AES-256-GCM kết hợp Nonce ngẫu nhiên. Dù kẻ trộm có lấy được toàn bộ file Database thì số CCCD vẫn vô nghĩa nếu không có Secret Key. Thứ hai, bảng nhật ký kiểm toán grade_audit_logs ghi vết chi tiết việc giảng viên sửa điểm từ 6.5 lên 8.0 với đầy đủ thời gian và lý do phúc khảo, đảm bảo tính toàn vẹn và bất khả chối bỏ."*

BÀI 7 **Chế Độ Tự Động Hóa Trọn Gói (Auto-Run Tất Cả Các Bài Trong 60s)**

Thao tác: Gõ số `7` rồi bấm **Enter**. Hệ thống tự động kích hoạt tuần tự toàn bộ 6 bài kiểm thử từ Bài 1 đến Bài 6 liên tục mà không cần can thiệp bàn phím, chứng minh sự ổn định tuyệt đối của hệ thống.

4. BỘ 7 CÂU HỎI PHẢN BIỆN CHUYÊN SÂU & CÂU TRẢ LỜI CHUẨN "ĐIỂM 10"

❓ **Câu hỏi 1 (A01): Nếu sinh viên tự sửa Session Cookie để đổi `user_id` thành của người khác thì có xem trộm điểm được không?**

Trả lời: Thưa Thầy, Flask Session sử dụng cơ chế **Cryptographically Signed Session** được ký bằng HMAC-SHA256 với `SECRET_KEY` lưu bí mật ở server. Cookie ở client chỉ chứa dữ liệu đã mã hóa kèm chữ ký số. Nếu sinh viên tự ý sửa dù chỉ 1 bit của `user_id` trong cookie, chữ ký số sẽ không còn khớp. Máy chủ Flask khi giải mã sẽ phát hiện chữ ký giả mạo, lập tức hủy bỏ toàn bộ phiên làm việc và đá người dùng về trang đăng nhập.

❓ **Câu hỏi 2 (A01): Tại sao khi sinh viên truy cập trái phép vào `/master`, nhóm lại chuyển hướng HTTP 302 thay vì trả về 403 Forbidden?**

Trả lời: Thưa Thầy, theo khuyến nghị của OWASP, việc trả về mã 403 Forbidden vô tình xác nhận cho kẻ tấn công biết rằng URL này thực sự tồn tại trên hệ thống (Information Disclosure). Bằng cách chuyển hướng 302 về trang Dashboard đúng vai trò, hệ thống vừa tối ưu trải nghiệm người dùng thông thường khi gõ nhầm link, vừa hạn chế tối đa việc hỗ trợ kẻ tấn công do thám cấu trúc ứng dụng.

❓ **Câu hỏi 3 (A03): Tại sao bắt buộc phải có thuộc tính `crossorigin="anonymous"` khi khai báo SRI? Nếu CDN bị sập mạng thì sao?**

Trả lời: Thưa Thầy, theo chính sách Same-Origin Policy của W3C, khi tải file JavaScript từ nguồn khác tên miền (Cross-Origin), nếu không có cờ `crossorigin="anonymous"`, trình duyệt sẽ không được phép đọc nội dung byte thô của file để tính mã băm SHA-256, dẫn đến việc kiểm tra SRI bị vô hiệu hóa. Về tính khả dụng: SRI bảo vệ tính toàn vẹn (Integrity), nếu CDN sập thì trang web mất hiệu ứng hộp thoại nhưng không bị lộ dữ liệu. Trong môi trường doanh nghiệp, giải pháp hoàn chỉnh nhất là tự lưu trữ nội bộ (Self-hosting) kết hợp CDN fallback có SRI.

❓ **Câu hỏi 4 (A07): Tại sao nhóm chọn khóa tài khoản trong 60 giây mà không khóa vĩnh viễn luôn? Nếu hacker dùng Botnet nhiều IP thì sao?**

Trả lời: Thưa Thầy, theo chuẩn NIST SP 800-63B, khóa vĩnh viễn sẽ tạo ra lỗ hổng Từ chối dịch vụ (DoS) vì kẻ xấu chỉ cần cố tình gõ sai tài khoản của bạn bè để cả trường bị khóa. Khóa 60s (Rate-limit) đủ làm tê liệt mọi công cụ dò quét tự động. Nếu hacker dùng Botnet đổi hàng nghìn IP, cơ chế **Dual-Scope Throttle** của EduFlaw vẫn đếm theo khóa `user:<account>` và khóa tài khoản đó trên phạm vi toàn cầu.

❓ **Câu hỏi 5 (A10): Tại sao nhóm lại coi việc trả về lỗi HTTP 500 là điểm yếu bảo mật (OWASP A10)?**

Trả lời: Thưa Thầy, mã lỗi HTTP 500 thường đi kèm với việc ứng dụng bị sập ngoại lệ chưa bắt (Unhandled Exception), dẫn đến rò rỉ Stack Trace, tên thư viện và câu lệnh SQL. Tin tặc sẽ lợi dụng các thông tin này để vẽ sơ đồ kiến trúc hệ thống và xây dựng payload khai thác chính xác. EduFlaw áp dụng nguyên tắc Fail-Closed: bắt gọn mọi ngoại lệ, ghi log nội bộ và trả về mã lỗi 400 cùng câu thông báo chung chung, giữ kín toàn bộ chi tiết kỹ thuật.

❓ **Câu hỏi 6: Khóa bí mật dùng để mã hóa số CCCD được lưu ở đâu? Nếu hacker dump được CSDL thì có giải mã được không?**

Trả lời: Thưa Thầy, khóa mã hóa CCCD (`SECRET_KEY`) được tách biệt hoàn toàn khỏi Database và chỉ lưu dưới dạng biến môi trường trong file `.env` trên hệ điều hành máy chủ. Dù hacker có Dump được toàn bộ file MySQL thì trong bảng `student_profiles` cũng chỉ thu được các chuỗi ngẫu nhiên `enc:v1:...`. Nếu không chiếm được quyền root máy chủ ứng dụng, dữ liệu CCCD của sinh viên an toàn tuyệt đối.

❓ **Câu hỏi 7: Nhóm làm thế nào để đảm bảo Giảng viên không tự ý sửa điểm rồi xóa vết trong CSDL?**

Trả lời: Thưa Thầy, hệ thống đảm bảo tính Bất khả chối bỏ (Non-repudiation) qua 3 tầng: 1. Giảng viên chỉ có quyền sửa điểm lớp mình phụ trách (Chống IDOR); 2. Mỗi thao tác lưu điểm đều tự động tạo 1 bản ghi vào bảng `grade_audit_logs` ghi rõ người sửa, giờ sửa, điểm cũ, điểm mới và lý do; 3. Giảng viên hoàn toàn không được cấp quyền `DELETE` trên bảng audit logs.